



German
OWASP
Day 2026



German
OWASP
Day 2026

New OWASP Kubernetes Top 10 in Action and Explained

Benjamin Koltermann

\$whoami

\$ id -u -n
Benjamin Koltermann

\$ id -g -n
cenroq AG

\$ ps -aux

PID	TTY	TIME
1	tty1	since August 2026
2	tty1	since DEF CON 29
3	tty1	since October 2018

CMD
CTO of cenroq AG
Kubernetes CTF organizer
CTF Player at Fluxfingers



OWASP Kubernetes Top 10: 2022 vs. 2025

What changed: two new risks, two merged into one, supply chain dropped

2025	Risk (2025 name)	2022	Change
K01	Insecure Workload Configurations	K01	Unchanged
K02	Overly Permissive Authorization Configurations	K03	Up 1, broadened from RBAC
K03	Secrets Management Failures	K08	Up 5
K04	Lack of Cluster Level Policy Enforcement	K04	Renamed (was centralized)
K05	Missing Network Segmentation Controls	K07	Up 2
K06	Overly Exposed Kubernetes Components	–	New
K07	Misconfigured and Vulnerable Cluster Components	K09 + K10	Merged
K08	Cluster to Cloud Lateral Movement	–	New
K09	Broken Authentication Mechanisms	K06	Down 3
K10	Inadequate Logging and Monitoring	K05	Down 5



01 K01: Insecure Workload Configurations

Security Context

Purpose and Outcome

Harden the Kubernetes Security Context for better isolation and least privileges of pods.

Challenges

- 1) Know what does not break applications
- 2) Enforcing rules during development



02 K02: Overly Permissive Authorization Configurations

Role Based Access Control (RBAC)

Purpose and Outcome

Be aware of various dangerous Kubernetes verbs:

- Node/proxy
- ESCALATE, BIND and IMPERSONATE
- PATCH
- "*"

LIST & WATCH on secrets reveal the secret value.

Implement least-privilege RBAC.

Challenges

- 1) Know all the RBAC tricks
- 2) Third-party-software from GitHub
- 3) Know what you really need



03 K03: Secrets Management Failures

Secret Management

Purpose and Outcome

Kubernetes Secrets are only Base64 encoded by default and plaintext in the etcd database.

Sensitive data is often used in different Kubernetes Objects, although it should always be a reference to a secret.

Challenges

- 1) Encrypt the etcd database
- 2) Use a vault or another secret manager:
 - HashiCorp/OpenBao
 - Sealed Secrets
 - SOPS
- 3) Use Kubernetes secrets for sensitive data



German
OWASP
Day 2026



04 K04: Lack Of Cluster Level Policy Enforcement

Admission Control

Purpose and Outcome

Regulate what is deployed into the Kubernetes Cluster

- Firewall/Bouncer for Kubernetes Objects

The Cluster only deploys harmless objects, with least privileges.

Challenges

- 1) Writing Admission Policies is complex!
- 2) What tool to use
 - ValidatingAdmissionPolicies
 - Kyverno
 - Open Policy Agent (OPA)
- 3) Policy Language
 - CEL
 - Rego



05 K05: Missing Network Segmentation Controls

Network Policies

Purpose and Outcome

By default every pod can talk to any other pod across all namespaces!

Isolate Namespaces and workloads on the network from each other.

Challenges

- 1) Managing Network Policies
 - Who writes these policies?
 - Use CNI-specific policies
- 2) Microservices use more network communication, which leads to more policies
- 3) Manage access to the policies



06 K06: Overly Exposed Kubernetes Components

Exposure Management

Purpose and Outcome

Regulate Access to Kubernetes API, Kubelet API and etcd Database.

Challenges

- 1) Usage of Jump Hosts
- 2) Firewalling
 - What ports are used?



07 K07: Misconfigured And Vulnerable Cluster Components

Core Component Hardening

Purpose and Outcome

Secure Kubernetes Optimized Distro

- Talos
- Flatcar

Harden Core Components with distro-specific Best Practices

- Kube-ApiServer
- Kube-Scheduler
- Kube-Controller-Manager
- Etcd

Challenges

- 1) Support and Operations
- 2) What are the Best Practices for the used Distro?



08 K08: Cluster-To- Cloud Lateral Movement

Kubernetes in Cloud Environments

Purpose and Outcome

Use Cloud identities in Kubernetes workloads to use Cloud IAM for least privilege assignment.

Block access to the metadata service to prevent token theft.

Challenges

- 1) Least Privilege
- 2) Automation often includes the Metadata Server.



09 K09: Broken Authentication Mechanisms

Authentication



Purpose and Outcome

Use external authentication provider with e.g. OIDC that integrates with enterprise identity proxies.

Disable anonymous auth so that all requests need to be authenticated. The */version* endpoint will be disabled.

Use short-lived Service Account tokens.

Disable Token Automount so that Pods do not have a token by default.

Challenges

- 1) Anonymous auth is often used by monitoring tooling. This tooling needs authentication after it is disabled.
- 2) Automount tokens need to be disabled manually.
- 3) Short lived tokens need the flag *--duration* at creation.



German
OWASP
Day 2026



10 K10: Inadequate Logging And Monitoring

Audit Logging



Purpose and Outcome

Export Logs and Log requests to the Kubernetes API by using Audit Logging

Kubernetes Audit Logging answers the following questions:

- What happened?
- When did it happen?
- Who initiated it?
- On what did it happen?
- Where was it observed?
- From where was it initiated?
- To where was it going?

Challenges

- 1) Log exporting should be configured and scalable
- 2) Writing good Kubernetes Audit Policy Files



11 Am I secure if I follow the OWASP Kubernetes Top 10?

More Kubernetes Security

OWASP just touches the built-in Kubernetes security.

What is still left:

- Service Mesh (Encryption in Transit)
- Supply Chain





German
OWASP
Day 2026

New OWASP Kubernetes Top 10 in
Action and Explained

Kubernetes can have lots of third-party-software. OWASP focuses on the built-in objects.



German
OWASP
Day 2026



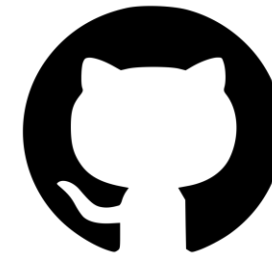
12 Demo

OWASP Top 10 in Action



German
OWASP
Day 2026

New OWASP Kubernetes Top 10 in
Action and Explained



OWASP Kubernetes Top 10 Demo

cenrc 



German
OWASP
Day 2026

THANK YOU!